

РОЗДІЛ 1. АНАЛІЗ ПРЕДМЕТНОЇ ОБЛАСТІ ДОСЛІДЖЕННЯ. ТЕХНІЧНЕ ЗАВДАННЯ

1.1. Огляд предметної області та об'єкта захисту

Мережевий трафік — це потік даних, що передається між пристроями в комп'ютерній мережі. Він включає HTTP/HTTPS-запити, DNS-запити, поштові повідомлення, VPN-з'єднання, трафік баз даних та інші протоколи. Аналіз мережевого трафіку є ключовим компонентом забезпечення кібербезпеки організації, оскільки дозволяє виявляти підозрілу активність, несанкціонований доступ та кібератаки.

Об'єктом захисту у цій роботі виступає мережева інфраструктура, побудована на базі контейнерної технології Docker. Інфраструктура включає:

- **Веб-сервер Nginx Proxy** — зворотний проксі-сервер, що обробляє вхідні HTTP/HTTPS-запити та маршрутизує їх до внутрішніх сервісів;
- **Веб-додаток WordPress** — система управління контентом, яка генерує значний обсяг HTTP-трафіку та є типовою мішенню для кібератак;
- **СУБД MySQL** — сервер баз даних, доступ до якого має бути обмежений та контрольований;
- **Система моніторингу Prometheus** — збір метрик продуктивності з експортерів;
- **Система логування Grafana Loki + Promtail** — централізований збір та зберігання логів усіх контейнерів;
- **AI-адаптер** — фоновий мікросервіс для автоматичного аналізу логів;
- **Telegram Bot** — сервіс сповіщень про інциденти безпеки.

Дана інфраструктура є типовою для малих та середніх організацій і представляє повний цикл: від генерації мережевого трафіку (веб-додаток) до його моніторингу та аналізу.

Характеристика інформаційних активів

[Таблиця 1.1 — Інформаційні активи системи \(формат Excel/XLSX\)](#)

1.2. Аналіз існуючих загроз мережевого трафіку

Класифікація кіберзагроз мережевого трафіку охоплює широкий спектр атак, які можна розділити на кілька категорій.

Зовнішні загрози

SQL Injection (SQLi) — впровадження шкідливого SQL-коду через вхідні параметри веб-додатку. За даними OWASP Top 10 (2021), ін'єкції залишаються однією з найбільш критичних вразливостей.

Cross-Site Scripting (XSS) — впровадження шкідливих скриптів у веб-сторінки, які виконуються у браузері жертви. Дозволяє викрадати сесійні токени та облікові дані.

Brute-force Attack — автоматизований перебір паролів для отримання несанкціонованого доступу до системи. Типово спрямований на адміністративні панелі (wp-login.php, wp-admin).

Remote Code Execution (RCE) — віддалене виконання коду на сервері через вразливості у програмному забезпеченні.

DDoS-атаки — розподілена відмова в обслуговуванні шляхом генерації надмірного обсягу мережевого трафіку.

DNS Tunneling — використання DNS-протоколу для прихованої передачі даних за межі мережі.

Внутрішні загрози

1. **Несанкціонований доступ** — спроби доступу до ресурсів без відповідних привілеїв.
2. **Data Exfiltration** — витік конфіденційних даних за межі організації.
3. **Resource Exhaustion** — вичерпання ресурсів системи (CPU, RAM, диск) внаслідок некоректної роботи або шкідливої активності.

Технічні загрози

1. **Database Connection Failure** — відмова з'єднання з базою даних, що може свідчити про атаку або збій конфігурації.
2. **Service Timeout** — тайм-аут сервісів, потенційно спричинений навантажувальними атаками.
3. **High Error Rate** — аномально високий рівень помилок, що може бути індикатором сканування вразливостей.

1.3. Огляд існуючих рішень для аналізу трафіку

Сигнатурні системи (IDS/IPS)

Snort — одна з найвідоміших IDS/IPS систем з відкритим вихідним кодом. Використовує правила (сигнатури) для виявлення відомих атак у мережевому трафіку. Переваги: висока швидкість, велика база правил. Недоліки: нездатність виявляти zero-day атаки, необхідність ручного оновлення правил.

Suricata — багатопотокова IDS/IPS з підтримкою аналізу прикладного рівня (Application Layer). Підтримує сигнатури Snort та власні правила. Переваги: висока продуктивність завдяки багатопоточності. Недоліки: складність налаштування, обмежений контекстний аналіз.

Zeek (Bro) — фреймворк для моніторингу мережевої безпеки. На відміну від Snort/Suricata, Zeek фокусується на аналізі метаданих з'єднань та генерації структурованих логів. Переваги: глибокий аналіз протоколів. Недоліки: не є IDS у класичному розумінні, потребує додаткових інструментів для виявлення загроз.

AI-based рішення

Darktrace — комерційна платформа, що використовує алгоритми машинного навчання для виявлення аномалій у мережевому трафіку. Концепція «Enterprise Immune System». Переваги: адаптивність, виявлення невідомих загроз. Недоліки: висока вартість ліцензії, закритий код.

Vectra AI — платформа для виявлення та реагування на загрози (NDR). Використовує AI для кореляції подій та пріоритезації загроз. Переваги: автоматизована пріоритезація. Недоліки: вимагає значних ресурсів, комерційна ліцензія.

SIEM-системи

ELK Stack (Elasticsearch, Logstash, Kibana) — відкрита платформа для збору, зберігання та візуалізації логів. Переваги: гнучкість, масштабованість. Недоліки: ресурсоємність, відсутність вбудованого AI-аналізу.

Grafana Loki — легковага система збору логів від Grafana Labs. На відміну від Elasticsearch, Loki індексує лише метадані (labels), а не весь вміст логів, що значно зменшує вимоги до ресурсів. Саме ця система використовується у розроблюваному вебдодатку.

[Таблиця 1.2 — Порівняльний аналіз існуючих рішень \(формат Excel/XLSX\)](#)

1.4. Роль великих мовних моделей у кібербезпеці

Великі мовні моделі (LLM) — це нейромережі-трансформери, навчені на великих обсягах текстових даних. У контексті кібербезпеки LLM мають кілька ключових переваг:

Контекстуальне розуміння — LLM здатні аналізувати текстові логи та мережеві дані з урахуванням контексту, виявляючи паттерни, які пропускають сигнатурні системи.

Класифікація загроз — модель може автоматично класифікувати виявлені загрози за типом (SQLi, XSS, Brute-force тощо) та визначати рівень ризику.

Генерація рекомендацій — LLM формує конкретні рекомендації щодо нейтралізації загрози людською мовою, що скорочує час реагування.

Адаптивність — на відміну від жорстких сигнатурних правил, LLM може адаптуватися до нових типів атак без необхідності ручного оновлення правил.

У розроблюваній системі використовується модель **Llama-3 (8B)** від Meta AI, яка запускається локально через платформу Ollama з апаратним прискоренням на GPU. Це забезпечує: - повну конфіденційність — дані не передаються зовнішнім сервісам; - низьку затримку — інференс виконується локально; - відсутність обмежень на кількість запитів; - незалежність від Інтернет-з'єднання.

1.5. Обґрунтування вибору технологій

На основі проведеного аналізу обрано наступний технологічний стек:

- **Python 3.11 + Flask** — серверна частина вебдодатку (REST API);
- **HTML5 + CSS3 + JavaScript (ES6+)** — клієнтська частина (SPA Dashboard);
- **Chart.js** — бібліотека для побудови інтерактивних графіків;
- **Ollama + Llama-3** — локальна LLM для аналізу трафіку;
- **Grafana Loki + Promtail** — збір та зберігання логів;
- **Prometheus** — збір метрик;
- **Alertmanager** — управління сповіщеннями;
- **Docker + Docker Compose** — контейнеризація та оркестрація;
- **Jenkins** — CI/CD pipeline;
- **Gunicorn** — WSGI-сервер для production.

1.6. Технічне завдання

1.6.1. Найменування та область застосування

Вебдодаток «NetVigil» призначений для автоматизованого аналізу мережевого трафіку з використанням LLM в організаціях малого та середнього масштабу, навчальних закладах та ІТ-компаніях.

1.6.2. Функціональні вимоги

1. Збір та відображення логів мережевих пристроїв з фільтрацією за контейнером, часом та ключовими словами.
2. Автоматичний аналіз логів за допомогою LLM з класифікацією за 10 категоріями загроз.
3. Завантаження та аналіз PCAP-файлів (до 10 МБ, формат libpcap).
4. Інтерактивний дашборд з графіками в реальному часі.
5. Перегляд історії алертів безпеки.
6. Чат-інтерфейс для діалогу з AI-асистентом.
7. Автоматичне сповіщення через Telegram при виявленні загроз.

1.6.3. Нефункціональні вимоги

- Час відповіді API (без LLM): не більше 2 секунд.
- Час аналізу LLM: не більше 60 секунд.
- Підтримка одночасної роботи до 10 користувачів.
- Адаптивний дизайн для десктопних та мобільних пристроїв.
- Робота без зовнішнього Інтернет-з'єднання (локальна LLM).

1.6.4. Вхідні та вихідні дані

Вхідні дані: - Логи контейнерів (текстовий формат, через Loki API); - PCAP-файли (бінарний формат libpcap); - Метрики системи (Prometheus API); - Повідомлення користувача (чат).

Вихідні дані: - JSON-відповіді API з результатами аналізу; - Візуалізація графіків (Chart.js); - Алерти в Alertmanager/Telegram; - Класифікація загроз з рекомендаціями.